

Configuration Documentation

AccessGaurd System

IAM Platform, System Components, Security Controls & RBAC

Overview

This document goes over the major configuration components. These reflect the main production-ready, hardened configurations that are valuable for the full sprint delivery.

The AccessGaurd system is a protective computing system that is designed to manage the security controls and enforce the integrity of the system using efficient workflows and monitoring mechanisms. This structure uses the Human Resources processes as well as the IT infrastructure making sure that each user has proper access and can create, remove and modify the proper controls in a secure and auditable manner.

The main goal of this program is to get rid of the manual intervention needed by IT in the routine management of accounts while still enforcing proper security controls like immediate deactivation, privileged access and proper audit logging. This makes sure that the strong security compliance and operational efficiency are accurate across each area of the lifecycle for employees. This structure uses an event-driven automation, changing the status of each employee within the HR system and triggering the previously created workflows of identity services, managing tools and security logging systems.

1. Access and Identity Management Configuration

The IAM component propose as the central authority for looking over the access permissions and user identities. It protects the creator, removal and maintenance of the user accounts. During the onboarding when an employee is added to the new HR system, the IAM system creates the users accounts automatically with the standard naming conventions. Temporary credentials are used to create the account and then the user has the responsibility to reset them once logged in.

The rights for access are not random but rather centralized using the Role-Based Access Control (RBAC). Each of the users are mapped in the RBAC and given their corresponding functions, with permissions which are granted through their role. This prevents over access and makes sure that users only have access to what is required. During the offboarding, the IAM structure disables the account of the user and terminates

it from the main HR system. The sessions which are active are then revoked, preventing the repetitive access using the authenticated connections. The assigned roles and access groups are then separated from the user, getting rid of all the permissions the user once had.

All of these actions such as login attempts, account creator and permissions changes are all recorded using the system logs to promote audit readiness and traceability.

2. Account Deactivation and Offboarding

When a user departs from the organization, the HR system automatically starts the offboarding event and start the process of deactivating the account from within the IAM system.

The account of the user is automatically disabled to stop any more attempts of authentication. Any active sessions which are running will be forcefully revoked making sure that the user does not have continuous access to prior authentication sessions. The user is then removed from previous security groups and any assigned roles, efficiently disabling all the permissions within the organizational system.

RBAC Engine Configuration

The role-based access control structure uses the Open Policy Agen (OPA). This system analyses the decisions of authorization choices using the proper policy rules. No permission denial or grants shall occur without the necessary policy evaluation of OPA.

Role Name	Trust Level	Department	Max Session	Key Permissions
System Administrator	Critical	IT Operations	12 hr max	Complete platform access, Full Vault permissions, user management and backup control
Security Administrator	Critical	Security Ops	8 hr max	SIEM access, incident response, report review, audit log export, user suspension
HR Administrator	High	Human Resources	8 hr max	User lifecycle (onboard/offboard), permission to view all profiles, no system configuration, run HR reports,
Department Manager		All Departments	8 hr max	View complete team access, submit final access requests, approve role changes for complete direct reports
Standard User	Standard	All Departments	8 hr max	Self-service password reset, Login, view self-profile, access designated applications
Read-Only Auditor	Standard	Compliance / Legal	4 hr max	View complete logs, run the compliance reports, export the audit trails — no write access

Role Name	Trust Level	Department	Max Session	Key Permissions
Service Account	High	Automated Systems	N/A	Scoped complete designated API access, client credentials OAuth flow, no interactive login
Contractor	Standard	External	4 hr max	Time-bound (max 90 days), limited scope, no admin surface permission, no data export

Automation Workflow Configuration

The layer for automation is in charge for executing the main offboarding and onboarding processes without the need for manual intervention. It acts as the main bridge between the IT infrastructure and the HR system, making sure that all of the employee's lifecycles are properly translated into the system real time.

When a new user is added in the system, the workflow for onboarding triggers the retrieval attributes such as their job title, department, employment status and then further uses this information to determine the proper access for the system. The account for the user is then created with the designated identity management roles; permission are uses based on the rules from the predefined organization.

In addition to the creation of the accounts, the system also provides the users with the necessary application enterprise which generates the credentials for the user. The ticket is created with the IT service management in order for the onboarding proves to be visible to the IT support team. The offboarding steps are started when an employee is stated to be terminated. The system automatically uses the user account as terminated all the sessions, disabling the account and the connected applications. Revocation of the access permission takes place. If a managed device is used during this process, the system automatically starts a secure data wipe to get rid of all of the information from the organization. All of the process is logged to maintain compliance and accountability.

Mechanisms for error handling are created within the system of automation to promote reliability. If any of the steps fails in the workflow, the system tries the operation again and further escalates the unresolves issues to the IT higher ups for manual intervention, this can be the IT administrator. This prevents the states from security risks during provisioning.

Permission	OPA Identifier	Roles Granted
User: Create	user:create	System Admin, HR Admin
User: Read (all)	user:read:all	Security Admin, System Admin, HR Admin, Manager, Auditor
User: Read (self)	user:read:self	All roles including Standard User
User: Update	user: update	System Admin, HR Admin
User: Delete	user: delete	System Admin (requires dual approval)
User: Suspend	user: suspend	HR Admin, System Admin, Security Admin
Role: Assign	role: assign	System Admin, HR Admin (manager-approved requests only)
Role: Read	role: read	HR Admin, System Admin, Security Admin, Manager, Auditor
Permission: Grant	permission: grant	System Admin only
Permission: Revoke	permission: revoke	System Admin, Security Admin
Audit Log: Read	audit: read	Auditor, System Admin, Security Admin
Audit Log: Export	audit: export	Security Admin, Auditor (4-eyes: two approvers required)
Incident: Create	incident:create	System Admin, Security Admin

1. Device Management Configuration

This component for device management ensures that each of the devices for the endpoint are within the security standards of the organization and stay under the control of the administration throughout the lifecycle for the employee.

All of the devices for corporate need to be enrolled into the system for device management prior to accessing the resources internally. The enrollment establishes a relationship for trust between the organization and device, allowing the administrators to use security policies and compliance with the monitoring.

The devices are further analyzed using the requirements of security that follow antivirus protection, encryption, secure configuration settings and system updates. Only the devices that are compliant can be granted the full access to the system for the organization. Devices that go against the compliance are then automatically restricted until the proper steps are taken to resolve the issues.

During the onboarding process, the devices are assigned to be configured with the security policies. During the offboarding process, the device is wiped out remotely to ensure that all of the private corporate data is removed. The device is also deregistered from the system of management to prevent the future access.

The continuous monitoring of the system is maintained throughout the proper usage. If any deviation takes place, the standards are generated which alert the IT team for review.

2. Service management Configuration

This system acts as the structure for creating the documentations for all of the offboarding and onboarding activities. It acts as the operational records to any IT behaviors that are performed throughout the entire lifecycle for the employee.

When the user starts the onboarding process, a service ticket is created which tracks the provisioning tasks. The ticket has the details for the employee, like the access, which is requested, and the status updates with each step being completed. This promotes transparency and gives the IT team pure visibility throughout the provisioning activities.

In comparison, during the offboarding process, another service ticket is developed that documents the full deactivation, device cleanup, and access removal. These tickets are logged and remain open until the full tasks are verified and completed.

Each of the ticket keeps the full history of audit, such as the system-generated updates and the timestamps. This promotes the full accountability and the complete compliance audit by giving a record that is traceable for IT operations.

3. Logging and Security Configuration

This section monitors the events that are critical throughout the lifecycle. These can include the authentication, identity changes, device compliance and automation execution.

The system logs each activity such as the permission modifications, login attempts, device management actions and account deactivation. These audits give the team a full record of the activity and are imperative for both compliance reporting and security monitoring.

The mechanisms for security monitoring look over the data to detect any abnormalities during the process such as unauthorized access attempts, failed login attempts or any incomplete offboarding processes. When an event like this is detected, the alerts are created which forward the logs to the IT administrators to start the investigation.

This information is retained as according to the organizational retention policies to help with the forensic analysis and regulatory compliance. The logs of authentication are stores for a short-term period of time, whereas the audit logs are retained for a longer period to maximize the traceability.

The regular reports for security are created to summarize the system activity, emphasizing the risks and promoting continuous improvement for security controls.

4. Database Configuration

The main data is stories in the PostgreSQL 16 operating within a replication configuration of a primacy-replica. The main node deals with the writes and is the main authority form of truth. It serves as a form of read-scale traffic and performs standby actions in case of a failover that is automatic. Both nodes communicate using an encrypted channel and use the same private subnet. There are also certain firewall (load balancer) rules which need to be followed.

Rule	Protocol	Port	Source	Action
HTTPS-IN	TCP	443	0.0.0.0/0 (internet)	ALLOW — moved to NGINX on 10.0.1.10
HTTP-REDIR	TCP	80	0.0.0.0/0 (internet)	ALLOW — 301 forwarded to HTTPS
SSH-ADMIN	TCP	22	10.0.10.0/24 (VPN)	ALLOW — admin SSH from VPN subnet only
ICMP-HEALTH	ICMP	—	10.0.0.0/8	ALLOW — health check pings in the private range
ALL-OTHER	ALL	ANY	0.0.0.0/0	DENY — default deny rest of the inbound

5. Authentication service – Keycloak

The service we are using for authentication is keycloak, which manages the federation identity using multi-factor authentication and OAuth 2.0 / OIDC. It serves as a form of proof for the user's identity.

Setting / Parameter	Value / Configuration	Purpose / Notes
Auth Protocol	OAuth 2.0 + OIDC	Standards-based; supports federated identity ad SSO.
MFA Policy	TOTP required (all users)	Google Authenticator / Authy compatible.
Password Policy	Min 12 chars, complexity enforced	Lowercase, Uppercase, digit, special char required.
Password History	Last 10 passwords blocked	Prevents the reuse of previously used credentials.
Login Attempt Limit	5 failures → 15-min logout	Threshold configurable per each realm.
Token Expiry (Access)	15 minutes	Short-lived tokens minimize the exposure window.
Token Expiry (Refresh)	8 hours	Refresh tokens will require the re-authentication after business day.
Brute Force Protection	Enabled (auto-lock)	Progressive delays and account lock on repeated failures.

6. System Limitations and Assumptions

Assumptions:

- Identity source: A LDAP or Corporate Active Directory do exist are the main head of identity. The Keycloak software goes against it.
- Network: The system assumes that the deployment will occur behind a VPN or corporate firewall.
- Email Service: Notification delivery is possible for SMTP.
- Hardware: 16GB RAM for each node, there are a minimum of 3 nodes for the Kuberstan cluster.
- Browser Support: For the admin dashboard there needs to be the following requirements; Firefox 100+, Chrome 100+, or Edge 100+.

Limitations:

- There is no provisioning of the SCIM: There are no automatic provisioning in the MVP like from the HR system (BambooHR, Workday).
- There are no privileged access workstations as the PAW is documented but not fully enforced into the endpoint of the MVP.
- There are geo-restrictions as the IP rules are created to require for manual configuration during the deployment process.
- The reporting has limitations as the compliance reports do require the Kibana to be manually exported.
- Multi-tenancy are not allowed with the architecture we have currently. For other organizations, a separate deployment would be required.